

BEFORE Placeholder

AFTER

Review Cadence by Tier (Ongoing Supplier Assurance)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence (this document): Annually

1. Purpose

This document defines the minimum ongoing assurance review cadence for third parties by tier (Critical / Important / Low), and the minimum evidence/validation expectations for each review.

2. Principles

- Reviews are **tiered and proportionate**.
- Trigger events override cadence (a trigger forces immediate review).
- Evidence should be **verifiable** and focused on controls that materially reduce risk (identity, access, logging, vulnerability management, incident readiness, sub-processors, resilience).
- Where a supplier cannot meet a minimum requirement, an exception must exist with compensating controls and an expiry date.

3. Minimum review cadence

3.1 Critical (Tier 1)

Minimum cadence:

- **Every 12 months** (full review), and
- **At renewal**, and
- **On trigger events**.

Additional minimum checks:

- **Quarterly** exception expiry review (at minimum).
- **Quarterly** confirmation of critical supplier contact details and incident notification paths.

3.2 Important (Tier 2)

Minimum cadence:

- **Every 24 months** (full review), and
- **At renewal** (if renewal occurs earlier than cadence), and
- **On trigger events**.

Additional minimum checks:

- **Quarterly** exception expiry review (where exceptions exist).

3.3 Low (Tier 3)

Minimum cadence:

- **Every 36 months** (light review), and
- **On trigger events**.

Default approach:

- Retain a lightweight posture and reassess primarily when scope changes.

4. Review types and depth

4.1 Full review (Critical/Important)

A full review **MUST** include:

- Confirmation of current scope (data, integrations, access, criticality)
- Evidence refresh appropriate to tier (see Section 5)
- Review of open gaps and remediation status
- Review of exceptions (still needed? expiry? compensating controls still valid?)
- Sub-processor list refresh and change notification confirmation
- Incident history review (supplier and integration-related)
- Confirmation of resilience posture where applicable (Critical minimum)

4.2 Light review (Low)

A light review SHOULD include:

- Scope confirmation
- Confirmation of any new data/integration/access
- Confirmation of incident contact details (where applicable)
- Confirmation of sub-processor visibility where personal data is involved

5. Minimum evidence expectations by tier

5.1 Critical (Tier 1) — minimum evidence refresh (annual)

Critical reviews MUST obtain and/or validate: Identity & access:

- Confirmation MFA enforced for admin access
- Confirmation SSO/RBAC model still applies (or documented deviation)
- Confirmation privileged access path and approvals remain in place

Logging & auditability:

- Confirmation audit logging remains enabled for admin/auth events
- Confirmation log retention still meets agreed requirements or exception exists

Vulnerability management:

- Confirmation of vulnerability management process and patch SLAs
- Evidence of independent testing within last 12 months where applicable (executive summary acceptable)

Incident readiness:

- Confirmation incident notification commitments remain current
- Review any incidents in period and supplier performance vs commitments

Sub-processors:

- Updated sub-processor list (or confirmation of published list)
- Confirmation of change notification commitments

Resilience (where service supports critical business service, elevated connectivity, or material data processing):

- Confirmation of backup/restore/DR posture and last test summary (high level acceptable)
- Confirmation RTO/RPO expectations remain aligned

5.2 Important (Tier 2) — minimum evidence refresh (24 months)

Important reviews MUST obtain:

- Confirmation MFA for admin access
- Confirmation data scope and integrations (SSO/API/agents) unchanged
- Updated vulnerability management statement and patch approach
- Incident notification contact confirmation
- Sub-processor update where applicable
- Logging/audit capability confirmation where the service supports it

5.3 Low (Tier 3) — minimum evidence refresh (36 months)

Low reviews SHOULD obtain:

- Confirmation scope unchanged (data/integration/access)

- Confirmation admin MFA where supported
- Confirmation incident contact
- Sub-processor update only if data processing is in scope

6. Trigger events (override cadence)

Any of the following triggers an out-of-cycle review:

- new data types or increased data volume (especially personal/financial/auth data)
- new integration type (API write access, agent deployment, connectivity)
- privileged access requested or expanded
- supplier security incident/breach affecting service scope
- material sub-processor change or new outsourcing arrangement
- significant architecture change (supplier or internal integration)
- change in criticality (service becomes business critical) (Full trigger list maintained in ``monitoring/01-trigger-events-and-reassessment.md``.)

7. Outputs and records

Each review MUST produce:

- Review record with date, tier, and scope confirmation
- Evidence received (or evidence not available + rationale)
- Updated gap log with owners and due dates
- Updated exception status (renew/close/replace) with expiry dates
- Decision outcome: Approved / Approved with Conditions / Escalate / Offboard planning (where required)

Records retention is governed by the program data retention policy.

8. Escalation

Escalate to program governance when:

- Critical supplier cannot provide minimum evidence without credible justification
- Exceptions are expiring without remediation or credible compensating controls
- Supplier incidents indicate systemic control weaknesses
- Material new connectivity/privileged access is introduced without approved patterns